

Web Application Vulnerability Assessment and Penetration Testing (VAPT) Report

1. Executive Summary

This assessment was conducted in a controlled lab environment to evaluate the security of a web application (DVWA). Critical vulnerabilities such as SQL Injection and Cross-Site Scripting (XSS) were identified. These flaws allowed unauthorized database access and execution of malicious scripts. Weak password practices further increased the risk. The application is highly vulnerable and requires immediate remediation.

2. Scope & Methodology (PTES)

The assessment followed the PTES methodology:

- Reconnaissance
- Scanning
- Exploitation
- Post-Exploitation
- Reporting

Target:

- **127.0.0.1 (DVWA)**

Tools Used:

- Burp Suite
 - SQLMap
 - Metasploit
 - Browser (Manual Testing)
-

3. Technical Findings

Finding 1: SQL Injection (Critical)

URL: /vulnerabilities/sqli/

Description:

The application fails to validate user input, allowing manipulation of SQL queries.

Payload Used:

1' OR '1'='1

Impact:

- Database dump possible
 - Sensitive user data extracted
-

Finding 2: Cross-Site Scripting (XSS) (Medium)

URL: /vulnerabilities/xss_r/

Payload:

Impact:

- JavaScript execution in browser
 - Session hijacking possible
-

Finding 3: Weak Passwords (High)

Extracted credentials were weak and easily cracked.

Examples:

- admin → password
- gordonb → abc123

Finding ID	Vulnerability	CVSS Score	Remediation
F001	SQL Injection	9.1	Use prepared statements
F002	XSS	6.5	Output encoding
F003	Weak Password	7.5	Enforce strong passwords

4. Findings Table

5. Exploitation Summary

- SQL Injection used to extract database
 - SQLMap automated exploitation
 - User credentials dumped
 - Reverse shell achieved using Metasploit
-

6. Post-Exploitation

System access was obtained through reverse shell.

Commands executed:

whoami → root
uname -a

This confirms full system-level access.

7. Evidence Collection

Item	Description	Collected By	Date	Hash Value
Traffic Log	HTTP Traffic	VAPT Analyst	2026-04-29	SHA256: sample123
Users Dump	DB Data	VAPT Analyst	2026-04-29	SHA256: sample456

8. Detection Log

Timestamp	Target IP	Vulnerability	PTES Phase
2026-04-29 10:00:00	127.0.0.1	SQL Injection	Exploitation
2026-04-29 10:10:00	127.0.0.1	XSS	Exploitation

9. Attack Path Diagram

(Insert your Google Drive diagram link here)
Attach screenshot of diagram.

10. Remediation Plan

- Use parameterized queries
- Validate and sanitize inputs
- Implement output encoding

- Use strong hashing (bcrypt)
 - Apply security headers
 - Perform regular security testing
-

11. Evidence Summary (50 words)

Evidence was collected by capturing HTTP traffic and extracting database contents after successful exploitation. Files were hashed using SHA256 to ensure integrity. Proper documentation was maintained, ensuring traceability and preserving all relevant data securely for further analysis and reporting.

12. Non-Technical Summary (100 words)

The security assessment identified critical vulnerabilities that could allow attackers to access sensitive data and compromise user accounts. Issues such as improper input validation and weak password practices were found. These weaknesses could lead to data breaches and misuse of user information. It is recommended to improve coding practices, enforce stronger security controls, and conduct regular testing. Addressing these vulnerabilities will significantly improve the overall security of the system and reduce potential risks.

13. Screenshots (Attach in Report)

- SQL Injection proof (browser output)
 - XSS alert popup
 - Burp Suite request/response
 - SQLMap output (DB dump)
 - Password cracking results
 - Metasploit shell (whoami, id)
 - Attack path diagram
-

14. Conclusion

The application is vulnerable to multiple high-risk issues including SQL Injection and XSS. Successful exploitation resulted in database compromise and potential account takeover. Immediate remediation is required to secure the application and prevent real-world attacks.